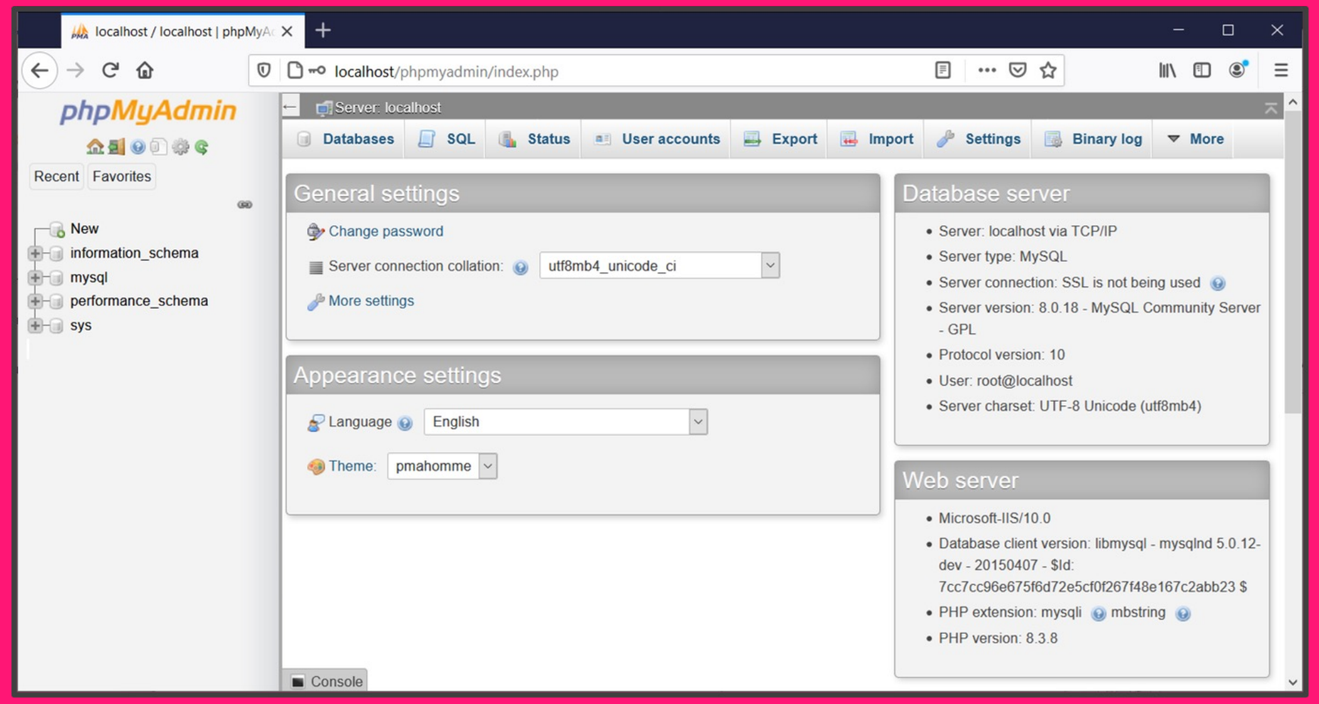
Using MySQL with PHP

Christian Wenz
Consultant, Software Architect

@chwenz



Database Setup

phpMyAdmin (https://phpMyAdmin.net/)

Disclaimer

There is more than one way ...

Very limited error handling/detection

Database uses insecure default settings

Database Connection

file.php

```
$db = mysqli_connect(
    'localhost',
    'user',
    'password',
    'database'
);
// ...
mysqli_close($db);
```

Inserting Data

```
mysqli_query(
    $db,
    "INSERT INTO table (col1, col2)
          VALUES ('value1', 'value2')");
```

SQL Injection

Injecting commands or clauses into SQL

```php
$sql = sprintf(
    "INSERT INTO table (col1, col2)
     VALUES ('%s', '%s')",
    mysqli_real_escape_string($db, 'value1'),
    mysqli_real_escape_string($db, 'value2'));
mysqli_query($db, $sql);
```

Preventing SQL Injection

Escaping values

```php
$stmt = mysqli_prepare(
    $db,
    "INSERT INTO table (col1, col2)
    VALUES (?, ?)");
mysqli_stmt_bind_param($stmt, 'ss', $value1, $value2);

mysqli_stmt_execute($stmt);
```

Preventing SQL Injection

Prepared statements